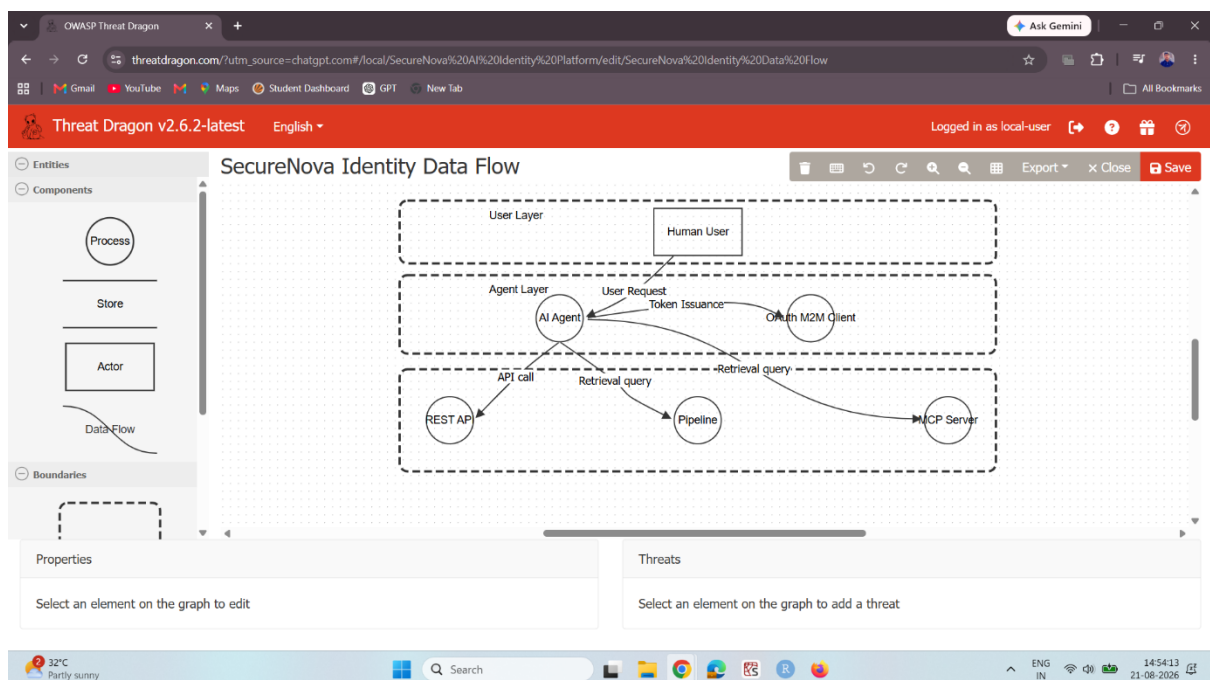


Project 1 — Threat Model

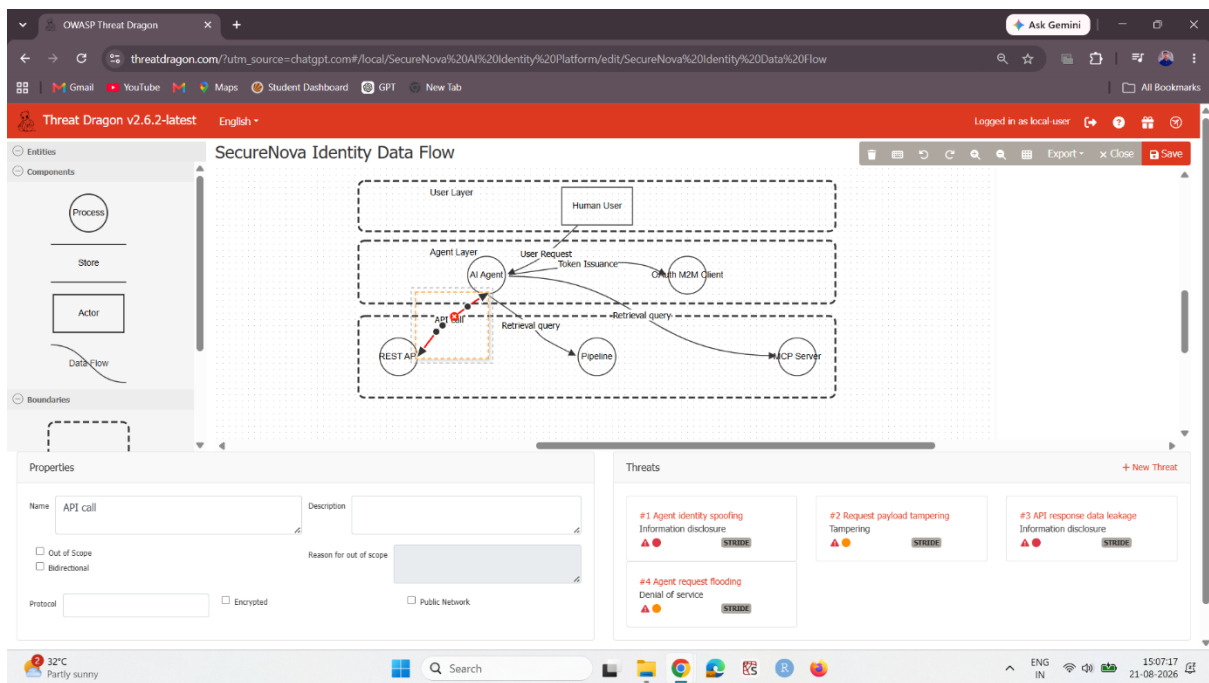
Screenshot 1 — OWASP Threat Dragon: Complete AI Identity Data-Flow Diagram

Shows the completed SecureNova AI identity-system data-flow diagram, including human users, AI agent, OAuth M2M client, LLM API key, RAG service identity, MCP server identity, and labelled trust boundaries.



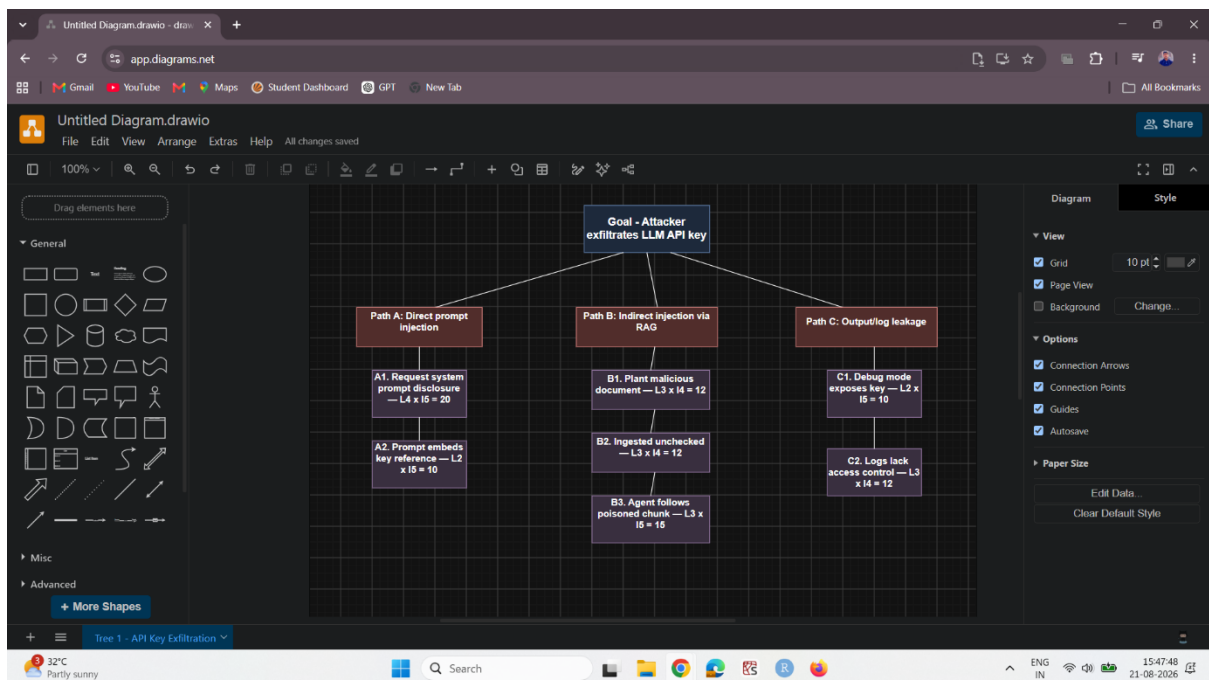
Screenshot 2 — OWASP Threat Dragon: STRIDE Threat Panel

Shows the Threat Dragon threat panel with at least three STRIDE threats identified for an identity flow, demonstrating the initial threat analysis.



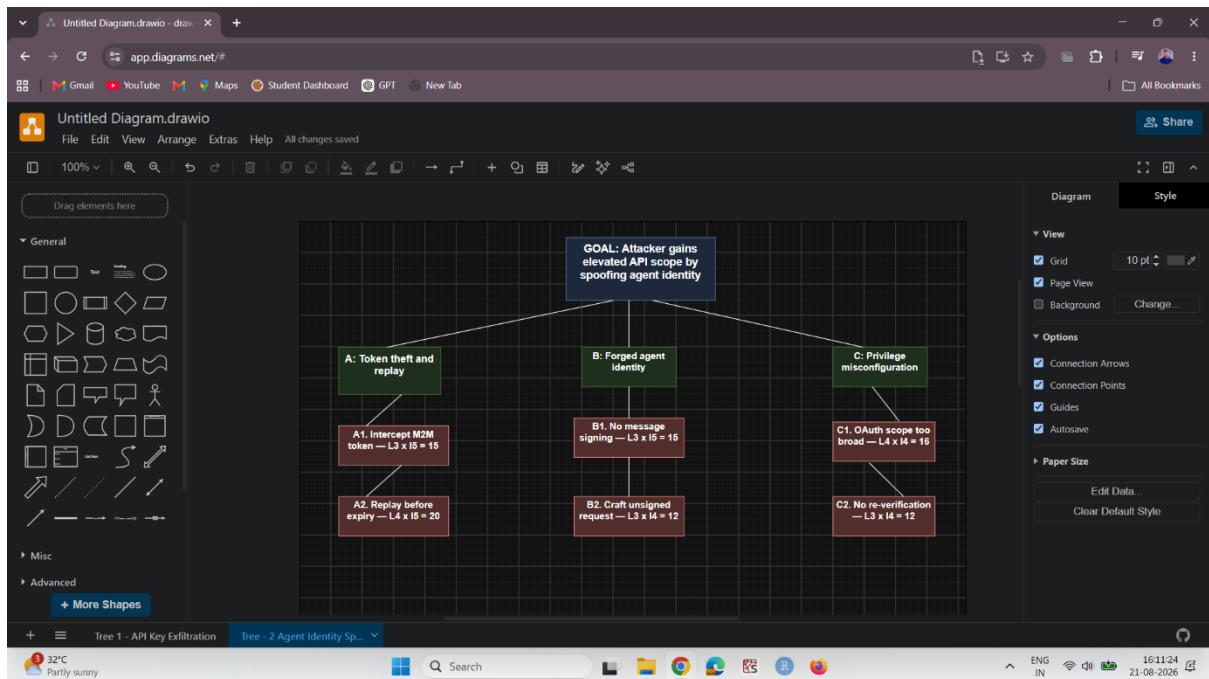
Screenshot 3 — Attack Tree 1: LLM API Key Exfiltration

Shows the draw.io attack tree for LLM API key exfiltration through prompt injection, with the attack goal and contributing attack paths/nodes visible.



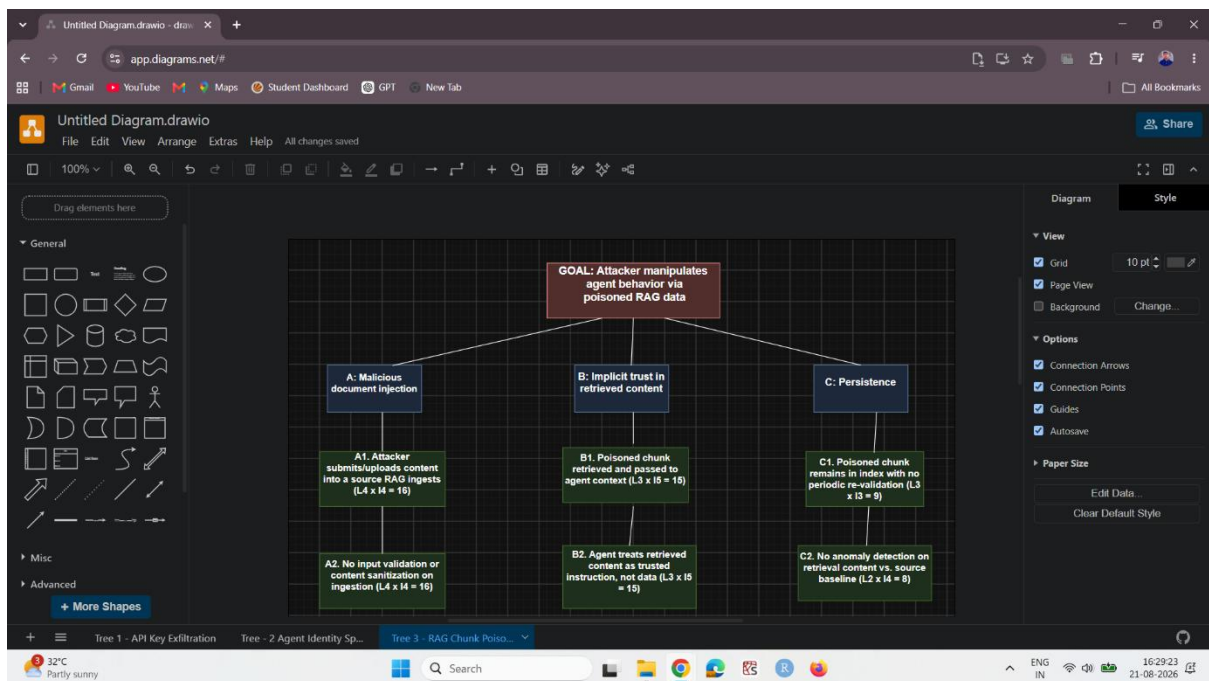
Screenshot 4 — Attack Tree 2: Agent Identity Spoofing

Shows the draw.io attack tree for agent identity spoofing to obtain elevated API scope, including the defined attack goal and associated nodes.



Screenshot 5 — Attack Tree 3: RAG Chunk Poisoning

Shows the draw.io attack tree for **RAG chunk poisoning**, illustrating how manipulated knowledge chunks can influence or alter AI-agent behaviour.



Screenshot 6 — Complete STRIDE Threat Matrix

Shows the fully populated STRIDE matrix covering all six categories—Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege—across the identified identity flows.

SecureNova AI Identity - STRIDE

docs.google.com/spreadsheets/d/1SSLE_ZWibf44jb_3asDhWw-4t4W7nKNz7Z5b5es8ADs/edit?gid=2049133249&gid=2049133249

Gmail YouTube Maps Student Dashboard GPT New Tab

SecureNova AI Identity - STRIDE Threat Matrix

File Edit View Insert Format Data Tools Gemini Extensions Help

95% \$ % .0 123 Roboto + - 10 B I Z A

C2

Summarize this data

	A	B	C	D	E	F	G	H	I	J	K	L	M	N
	STRIDE Threat MATRIX													
	Flow	Spoofing	Tampering	Repudiation	Information disclosure	Denial of service	Elevation of privilege							
1														
2	User → AI Agent	Attacker impersonates a legitimate user session	User request payload modified in transit	User denies issuing a harmful instruction	Agent reveals another user's data via session mixing	Flooding the agent with requests to exhaust capacity	Prompt causes agent to act beyond user's permission level							
3	AI Agent → REST API	Agent identity spoofed via stolen/replayed M2M token	API request payload altered before reaching REST API	No audit trail proving which agent instance made the call	Sensitive API response data exposed in agent logs	Agent sends excessive calls, exhausting backend capacity	Agent invokes endpoints beyond its intended scope							
4	AI Agent → RAG Pipeline	Malicious actor impersonates the RAG service identity	Poisoned/altered chunks injected into knowledge base	No record of which chunk influenced a given response	RAG pipeline returns confidential documents to unauthorized queries	Repeated retrieval queries overload the vector database	Agent retrieves data outside its permitted knowledge scope							
5	AI Agent → MCP Server	Attacker spoofs agent identity to invoke tools directly	Tool invocation parameters modified in transit	No signed record of which session triggered a tool action	MCP tool output leaks internal system details	Rapid repeated tool invocations exhaust server resources	Agent invokes a tool with more system access than intended							
6	OAuth M2M Client → AI Agent	Attacker requests tokens using stolen client credentials	Token claims modified after issuance	No logging of which client requested a given token	Token payload exposes internal scope/role details	Repeated token requests exhaust Auth0 rate limits	Token issued with broader scope than the requesting flow needs							

Sheet2

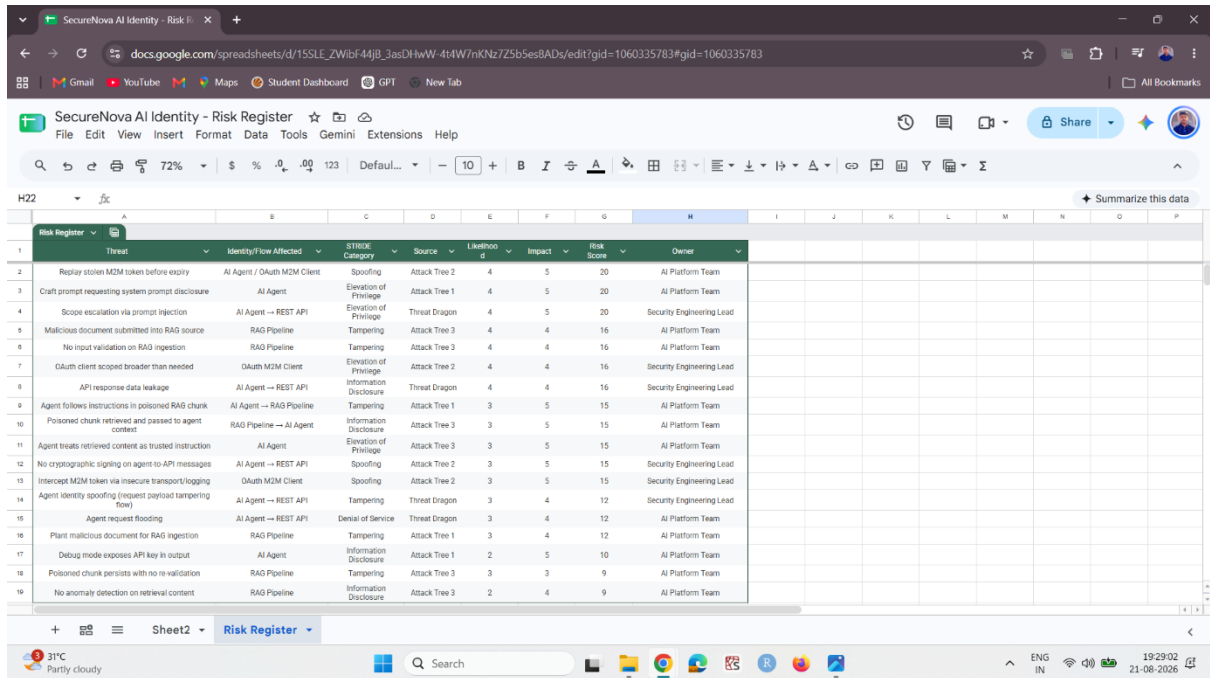
31°C Partly cloudy

Search

ENG IN 1901:34 21-08-2026

Screenshot 7 — Risk Register: Scored and Ranked Threats

Shows the completed risk register with threats evaluated using $\text{Likelihood} \times \text{Impact} = \text{Risk Score}$, with the threats scored, ranked, and assigned to owners.



The screenshot displays a Google Sheet titled "SecureNova AI Identity - Risk Register". The sheet contains a table with the following columns: Threat, Identity/Flow Affected, STRIKE Category, Source, Likelihood, Impact, Risk Score, and Owner. The table lists 19 threats, each with a corresponding risk score and assigned owner.

Threat	Identity/Flow Affected	STRIKE Category	Source	Likelihood	Impact	Risk Score	Owner
Replay stolen M2M token before expiry	AI Agent / OAuth M2M Client	Spoofing	Attack Tree 2	4	5	20	AI Platform Team
Craft prompt requesting system prompt disclosure	AI Agent	Elevation of Privilege	Attack Tree 1	4	5	20	AI Platform Team
Scope escalation via prompt injection	AI Agent → REST API	Elevation of Privilege	Threat Dragon	4	5	20	Security Engineering Lead
Malicious document submitted into RAG source	RAG Pipeline	Tampering	Attack Tree 3	4	4	16	AI Platform Team
No input validation on RAG ingestion	RAG Pipeline	Tampering	Attack Tree 3	4	4	16	AI Platform Team
OAuth client scoped broader than needed	OAuth M2M Client	Elevation of Privilege	Attack Tree 2	4	4	16	Security Engineering Lead
API response data leakage	AI Agent → REST API	Information Disclosure	Threat Dragon	4	4	16	Security Engineering Lead
Agent follows instructions in poisoned RAG chunk	AI Agent → RAG Pipeline	Tampering	Attack Tree 1	3	5	15	AI Platform Team
Poisoned chunk retrieved and passed to agent context	RAG Pipeline → AI Agent	Information Disclosure	Attack Tree 3	3	5	15	AI Platform Team
Agent treats retrieved content as trusted instruction	AI Agent	Elevation of Privilege	Attack Tree 3	3	5	15	AI Platform Team
No cryptographic signing on agent-to-API messages	AI Agent → REST API	Spoofing	Attack Tree 2	3	5	15	Security Engineering Lead
Intercept M2M token via insecure transport/logging	OAuth M2M Client	Spoofing	Attack Tree 2	3	5	15	Security Engineering Lead
Agent identity spoofing (request payload tampering flow)	AI Agent → REST API	Tampering	Threat Dragon	3	4	12	Security Engineering Lead
Agent request flooding	AI Agent → REST API	Denial of Service	Threat Dragon	3	4	12	AI Platform Team
Plant malicious document for RAG ingestion	RAG Pipeline	Tampering	Attack Tree 1	3	4	12	AI Platform Team
Debug mode exposes API key in output	AI Agent	Information Disclosure	Attack Tree 1	2	5	10	AI Platform Team
Poisoned chunk persists with no re-validation	RAG Pipeline	Tampering	Attack Tree 3	3	3	9	AI Platform Team
No anomaly detection on retrieval content	RAG Pipeline	Information Disclosure	Attack Tree 3	2	4	9	AI Platform Team

Screenshot 8 — MITRE ATLAS: AML.T0051 LLM Prompt Injection

Shows the MITRE ATLAS technique page for one of the attack trees, providing the corresponding AML.TXXXX technique ID used for the attack-path mapping.

LLM Prompt Injection | MITRE

atlas.mitre.org/techniques/AML10051

GmailYouTubeMapsStudent DashboardGPTNew Tab

All Bookmarks

MITRE ATLAS

MatrixTacticsTechniquesMitigationsCase StudiesToolsResourcesContribute

Reconnaissance

Resource Development

Initial Access

AI Model Access

Execution

AI Agent Clickbait

AI Agent Tool Invocation

Command and Scripting Interpreter

Deploy AI Agent

LLM Prompt Injection

Direct

Indirect

Triggered

User Execution

Unsafe AI Artifacts

Malicious Package

Poisoned AI Agent Tool

Malicious Link

HomeTechniquesLLM Prompt Injection

Subtechniques

An adversary may craft malicious prompts as inputs to an LLM that cause the LLM to act in unintended ways. These "prompt injections" are often designed to cause the model to ignore aspects of its original instructions and follow the adversary's instructions instead.

Prompt injections can be an initial access vector to the LLM that provides the adversary with a foothold to carry out other steps in their operation. They may be designed to bypass defenses in the LLM, or allow the adversary to issue privileged commands. The effects of a prompt injection can persist throughout an interactive session with an LLM.

Malicious prompts may be injected directly by the adversary (**Direct**) either to leverage the LLM to generate harmful content or to gain a foothold on the system and lead to further effects. Prompts may also be injected indirectly when the LLM, as part of its normal operation, ingests the malicious prompt from another data source (**Indirect**). This type of injection can be used by the adversary to gain a foothold on the system or to target the user of the LLM. Malicious prompts may also be **Triggered** by user actions or system events.

Procedure Examples

ID	Name	Actor	Tactic	Description
	Data Exfiltration via Agent Tools in	Zenitv		The researchers modify the original prompt to discover other knowledge sources and tools that

ID: AML10051

Tactics: Execution

Maturity: Realized

Platforms: Agentic AIGenerative AI

Number of Case Studies: 1

Number of Mitigations: 7

Created: 25 October 2023

Last Modified: 27 May 2026

Version Permalink (v2026.07)

31°CPartly cloudy

Search

ENGIN19:37:2621-08-2026